

SỔ ĐĂNG KÝ RỦI RO

Hệ thống Quản lý và Số hóa Tài liệu Thư viện HCMUS (HCMUS-LDMS)

Thông tin tài liệu

Trường	Nội dung
Mã tài liệu	HCMUS-LDMS-RSK
Chủ sở hữu	Project Manager — Mạch Quốc Tấn
Người xem xét	Solution Architect, QA và Đại diện nghiệp vụ Thư viện
Phiên bản	1.0 — 22/08/2026
Trạng thái	Bản dự thảo để xem xét
Baseline	MVP môn học 11 tuần; 15 Bắt buộc, 6 Nên có, 5 Có thể xem xét

Mục lục

- 1. Mục đích và nguyên tắc
- 2. Phương pháp đánh giá
- 3. Sổ đăng ký rủi ro
- 4. Kế hoạch ứng phó chi tiết
- 5. Ngưỡng báo cáo và nhịp rà soát
- 6. Rủi ro tồn dư và điều kiện chấp nhận
- 7. Truy vết

1. Mục đích và nguyên tắc

Sổ đăng ký này tập trung các rủi ro có thể ảnh hưởng đến phạm vi, tiến độ, chất lượng, dữ liệu, bảo mật và khả năng nghiệm thu của HCMUS-LDMS. Mỗi rủi ro có một owner chịu trách nhiệm theo dõi, trigger quan sát được, biện pháp phòng ngừa và phương án dự phòng.

Nguyên tắc áp dụng:

- Không xem rủi ro là đã đóng khi biện pháp mới chỉ được ghi trong tài liệu.
- Không dùng trạng thái **Đã xử lý** nếu chưa có evidence cho hành động tương ứng.
- Rủi ro có thể được chấp nhận, giảm thiểu, tránh hoặc chuyển giao; người chấp nhận phải có thẩm quyền đối với tác động đó.
- Issue đã xảy ra được chuyển sang board/Project Log và vẫn liên kết về Risk ID ban đầu.
- Mở rộng phạm vi, thay đổi môi trường hoặc dùng dữ liệu thật phải kích hoạt rà soát lại toàn bộ rủi ro liên quan.

2. Phương pháp đánh giá

2.1. Thang xác suất và tác động

Điểm	Xác suất	Hướng dẫn	Tác động	Hướng dẫn
1	Hiếm	Khó xảy ra trong baseline 11 tuần	Không đáng kể	Không ảnh hưởng mốc; sửa trong luồng thường
2	Thấp	Có thể xảy ra nhưng chưa có dấu hiệu	Nhỏ	Ảnh hưởng một hạng mục, không đổi mốc
3	Trung bình	Có tín hiệu hoặc phụ thuộc chưa chắc chắn	Vừa	Gây rework hoặc chậm một mốc nội bộ
4	Cao	Đã có tiền lệ, phụ thuộc yếu hoặc nguồn lực căng	Lớn	Đe dọa story Bắt buộc hoặc UAT
5	Rất cao	Đang xảy ra hoặc gần như chắc chắn	Nghiêm trọng	Phá baseline, vi phạm quyền hoặc mất dữ liệu

Điểm rủi ro = Xác suất × Tác động:

Điểm	Mức	Cách xử lý
1–4	Thấp	Owner theo dõi; rà soát tại mốc liên quan
5–9	Trung bình	Có hành động phòng ngừa và ngày rà soát
10–15	Cao	Báo PM; hành động trước khi kéo việc phụ thuộc
16–25	Rất cao	Dừng hoặc giới hạn hoạt động gây rủi ro; cần quyết định/ngoại lệ rõ

2.2. Trạng thái

Đang theo dõi — đang theo dõi; **Đã xảy ra** — trigger đã xảy ra; **Đang giảm thiểu** — đang thực hiện hành động; **Đã chấp nhận** — người có thẩm quyền chấp nhận tồn dư; **Đã đóng** — nguyên nhân không còn hoặc giai đoạn đã kết thúc và có evidence.

3. Sổ đăng ký rủi ro

ID	Rủi ro	P	I	Điểm	Mức	Owner	Trigger chính	Trạng thái
R-01	Chưa xác nhận quyền số hóa/đọc tài liệu thật	4	5	20	Rất cao	PM + Đại diện nghiệp vụ	Có yêu cầu đưa tài liệu thật vào demo nhưng không có xác nhận quyền	Đang theo dõi
R-02	Chất lượng OCR không đủ cho tài liệu mẫu	4	4	16	Rất cao	Solution Architect	CER/WER hoặc rà soát mẫu không đạt ngưỡng sẽ chốt trước PoC	Đang theo dõi
R-03	Mất hoặc ghi đè tệp gốc/nội dung đã hiệu chỉnh	3	5	15	Cao	Backend Lead	Hash/phiên bản sai, tệp không mở được hoặc retry làm mất dữ liệu	Đang theo dõi
R-04	Truy cập trái phép tệp riêng tư hoặc dữ liệu chưa xuất bản	4	5	20	Rất cao	Backend Lead + QA	Negative authorization test trả nội dung/URL hợp lệ	Đang theo dõi
R-05	Scope creep phá buffer 8 giờ	5	4	20	Rất cao	PM	Đưa story tùy chọn vào WIP hoặc forecast vượt capacity 198 giờ	Đang theo dõi
R-06	Thiếu đại diện nghiệp vụ để xác nhận AC/UAT	4	4	16	Rất cao	PM	AC chờ quá 3 ngày làm việc hoặc chưa có người xác nhận trước UAT	Đang theo dõi
R-07	Job OCR/EPUB treo hoặc mất khi backend restart	4	4	16	Rất cao	Solution Architect	Job processing vượt timeout hoặc không phục hồi sau restart	Đang theo dõi
R-08	Demo cloud khác local và thất bại sát hạn	3	4	12	Cao	DevOps Lead	Smoke test cloud lỗi hoặc cấu hình môi trường khác nguồn chuẩn	Đang theo dõi
R-09	Bí mật/credential bị đưa vào Git hoặc frontend	3	5	15	Cao	DevOps Lead	Secret scan/codereview phát hiện token, key hoặc connection string	Đang theo dõi
R-10	Tìm kiếm chậm hoặc lọc quyền không đúng	3	4	12	Cao	Backend Lead + QA	Dataset test cho kết quả sai quyền hoặc percentile vượt ngưỡng UAT	Đang theo dõi
R-11	EPUB tạo ra không hợp lệ/không đọc được	3	4	12	Cao	Backend Lead	Validator hoặc trình đọc mục tiêu không mở được EPUB	Đang theo dõi

ID	Rủi ro	P	I	Điểm	Mức	Owner	Trigger chính	Trạng thái
R-12	Không đủ evidence để chứng minh story Done	5	4	20	Rất cao	QA Lead + PM	Card ở Chờ xác nhận thiếu PR/test/reviewer/UAT	Đã xảy ra
R-13	Thành viên quá tải hoặc WIP vượt giới hạn	4	3	12	Cao	PM	Thành viên có hơn 1 card đang làm hoặc board vượt WIP	Đang theo dõi
R-14	Thay đổi yêu cầu/kiến trúc không đồng bộ tài liệu	4	3	12	Cao	PM + Solution Architect	Mâu thuẫn ID, scope, môi trường hoặc quyết định giữa hai nguồn	Đang theo dõi
R-15	Dữ liệu thử lẫn với dữ liệu thật hoặc chứa PII không cần thiết	3	5	15	Cao	QA Lead	Dataset không có nguồn/quyền hoặc chứa dữ liệu nhận diện cá nhân	Đang theo dõi
R-16	Backup/restore chỉ tồn tại trên giấy	3	5	15	Cao	DevOps Lead	Không có restore drill hoặc bản sao không khôi phục được	Đang theo dõi
R-17	Phụ thuộc dịch vụ cloud/free tier thay đổi hoặc hết hạn mức	3	3	9	Trung bình	DevOps Lead	Quota/cost/availability ngăn smoke test hoặc demo	Đang theo dõi
R-18	Lỗi accessibility/responsive cản trở đọc tài liệu	3	3	9	Trung bình	Frontend Lead + QA	Browser/device/accessibility checklist có lỗi chặn luồng đọc	Đang theo dõi

4. Kế hoạch ứng phó chi tiết

ID	Chiến lược	Phòng ngừa	Dự phòng khi trigger xảy ra	Evidence đóng/giảm mức
R-01	Tránh	Chỉ dùng bộ mẫu có nguồn và xác nhận quyền; lưu thông tin nguồn	Gỡ tài liệu khỏi môi trường, khóa truy cập, báo PM/nghiệp vụ	Danh sách dataset được duyệt và xác nhận người có thẩm quyền
R-02	Giảm	PoC sớm; chọn mẫu đa dạng; giữ bước hiệu chỉnh con người	Giảm tuyên bố chất lượng, đổi tiền xử lý/cấu hình hoặc giới hạn loại tài liệu	Báo cáo PoC có dataset, ground truth, công thức và kết quả
R-03	Giảm	Object key bất biến; version/hash; không ghi đè source	Cô lập job, khôi phục từ version/backup và điều tra audit log	Test integrity + restore evidence
R-04	Tránh/Giảm	Server-side RBAC; private bucket; URL tạm thời; negative tests	Thu hồi credential/URL, khóa endpoint, phân tích phạm vi ảnh hưởng	Authorization matrix và test pass
R-05	Tránh	Khóa 15 Bắt buộc; cấm kéo tùy chọn khi core chưa ổn định	Loại/hoãn scope qua Change Request; tái forecast	Board và CR thể hiện quyết định
R-06	Giảm	Chốt người đại diện và lịch review trước khi đưa card vào Ready	Ghi Pending; không tự chuyển Done; escalates sponsor/giảng viên	Xác nhận có ngày/người
R-07	Giảm	Timeout, attempt, heartbeat/recovery rule và retry idempotent	Đánh dấu failed/recoverable; retry có kiểm soát; bảo toàn dữ liệu	Restart/timeout/retry test pass
R-08	Giảm	Deploy/smoke sớm; cấu hình theo biến môi trường; runbook	Dùng local demo đã kiểm chứng và ghi rõ giới hạn	Cloud smoke evidence hoặc quyết định fallback
R-09	Tránh	 ngoài Git; least privilege; secret scan/review	Rotate/revoke ngay; xóa khỏi bản phát hành; đánh giá lịch sử Git	Secret scan pass và biên bản rotate nếu xảy ra
R-10	Giảm	Dataset chuẩn; index; lọc quyền trong truy vấn server	Giới hạn dataset/demo; sửa query/index; không công bố NFR chưa đo	Functional + performance evidence
R-11	Giảm	Validate EPUB; kiểm thử ít nhất hai reader mục tiêu	Không publish artifact lỗi; quay lại bản trước; ghi nguyên nhân	Validator và reader smoke pass
R-12	Giảm	Evidence template là bắt buộc trong DoD	Chuyển card về Đang xem xét; bổ sung test/review; không hồi tố giả	Completion event đủ trường

ID	Chiến lược	Phòng ngừa	Dự phòng khi trigger xảy ra	Evidence đóng/giảm mức
R-13	Giảm	WIP 1/người, 6 development, 4 review; swarm blocker	Dừng kéo việc, hỗ trợ card già nhất, điều chỉnh owner	Board về đúng WIP và blocker log
R-14	Giảm	ADR/CR và source-of-truth matrix	Dừng phát hành tài liệu; sửa tất cả nguồn bị ảnh hưởng	Link ADR/CR và lint/link check pass
R-15	Tránh	Data inventory; tối thiểu hóa PII; tách test/real	Cô lập/xóa theo phê duyệt, đổi credential, thông báo owner	Dataset register và kiểm tra truy cập
R-16	Giảm	Định nghĩa RPO/RTO mục tiêu cho demo; tạo backup có kiểm tra	Dừng thay đổi dữ liệu, restore bản gần nhất, ghi mất mát	Restore drill pass có thời gian và phạm vi
R-17	Chấp nhận/Giảm	Theo dõi quota; không phụ thuộc một tính năng độc quyền	Chuyển local/fallback service qua quyết định kỹ thuật	Quota check và smoke result
R-18	Giảm	Browser/device matrix; keyboard/contrast/zoom checks	Sửa lỗi chặn trước UAT hoặc ghi ngoại lệ được duyệt	Checklist và evidence theo phiên bản

5. Ngưỡng báo cáo và nhịp rà soát

- PM rà soát sổ rủi ro tối thiểu hai lần mỗi tuần và trước các mốc tuần 3, 7, 9, 10, 11.
- Risk owner cập nhật ngay khi trigger xảy ra, điểm thay đổi hoặc hành động quá hạn.
- Rủi ro từ 16 điểm phải được đưa vào cuộc họp gần nhất; hoạt động gây tác động pháp lý, mất dữ liệu hoặc lộ quyền phải tạm dừng.
- Rủi ro 10–15 điểm phải có hành động, owner và ngày rà soát trước khi hạng mục phụ thuộc vào cột Đang thực hiện.
- Risk review không thay thế defect triage, security incident hoặc Change Request.

6. Rủi ro tồn dư và điều kiện chấp nhận

Nhóm tồn dư	Người có thể chấp nhận	Điều kiện tối thiểu
Scope/tiến độ nội bộ	PM và nhóm	Có forecast mới và không che giấu story Bắt buộc bị loại
Nghiệp vụ/UAT	Đại diện nghiệp vụ	Có danh sách ngoại lệ, tác động và ngày xác nhận
Bảo mật/dữ liệu/quyền	Không tự chấp nhận bởi developer	Cần PM, owner dữ liệu/nghiệp vụ và người có thẩm quyền phù hợp
Kiến trúc demo	Solution Architect + PM	Có PoC/smoke evidence và giới hạn được công bố

Tại thời điểm lập tài liệu, chưa có rủi ro nào được đóng bằng evidence. **R-12** được đánh dấu **Đã xảy ra** vì Project Log xác nhận chưa có completion event lịch sử đủ bằng chứng.

7. Truy vết

Nhóm rủi ro	Nguồn liên quan
Quyền dữ liệu, scope và nghiệm thu	SOW, Feasibility
Bảo mật, job, integrity và môi trường	Architecture, SRS
WIP, evidence và thay đổi	Process, Team Contract, Project Log
Kiểm thử và chấp nhận	Test and UAT Plan, Quality Plan
Backup, incident và secrets	Operations and Security Plan